

이 커밋은 누가 승인했는가?

거버넌스 내재형 AI 통신 프로토콜 PAPER

Patrick Rho
Patty Co., Ltd.

2026년 8월

초록

AI 코딩 에이전트는 비공개 저장소를 읽고, 외부로 전송할 정보를 선별하며, 모델과 도구를 호출하고, 파일을 수정하여 커밋까지 생성한다. 그러나 커밋이 만들어진 뒤에는 기본적인 책임성 질문, 즉 **누가 이 결과를 만들어낼 권한을 부여했는가**에 답하기 어렵다. 기존 시스템에서도 API 자격 증명, 게이트웨이의 판단 기록, 도구 실행 로그, Git 이력을 통해 답의 일부를 찾을 수는 있다. 그러나 인간의 지시에서 모델 호출을 거쳐 실제 시스템 변경에 이르는 전 과정이 처음 부여된 권한 범위 안에서 수행되었음을 일관되게 입증하지는 못한다. 이러한 한계는 서로 독립적으로 생성된 기록을 사후에 연결하는 방식이 아니라, 권한 정보를 포함한 교환 단위를 요구한다.

본 논문은 거버넌스를 AI 통신 과정에 직접 포함하는 상태 기반 프로토콜 PAPER(Patty AI Provenance & Enforcement Relay)를 제안한다. 핵심 개념인 Governed Exchange는 등록 피어와 사용자의 신원을 단기 Capability Lease, 변경 불가능한 Policy Epoch, Relay의 실시간 판정, 서버가 관리하는 모델 패키지 및 실행 엔드포인트, 콘텐츠 해시 기반 Provenance Spine과 하나의 교환 단위로 묶는다. 모델은 작업을 제안할 수 있지만 그 작업을 실행할 권한까지 스스로 만들어낼 수는 없다. 감사 증거 역시 사후에 여러 로그를 이어 붙여 구성하는 것이 아니라 실제 처리 경로에서 함께 생성된다.

PAPER는 공개 명세와 구현체를 함께 제공한다. 구현 범위는 프로토콜 코어, Relay, Control Plane, PIA, 정책, 모델 레지스트리, Lease, 프로비넌스를 포괄하며, 공식 Patty Code Harness는 PAPER를 서비스 추론 경로로 사용한다. 재사용 가능한 PIA 인터페이스는 vLLM, SGLang, 사용자 정의 엔진을 지원한다. 공통 의미 계층은 채팅, 스트리밍, 도구 호출, 구조화 출력, 멀티모달 입력, 캐시, compaction을 표현하므로 동일한 프로토콜을 코딩 에이전트와 다른 AI 응용에 적용할 수 있다. Apple M4 Pro 환경에서 1 KiB Record 왕복, 증거 체인 갱신, 객체 다이제스트, Ed25519 서명 및 검증으로 구성된 비교 연산 묶음의 처리 시간은 43.45 μ s였다. 이는 MLPerf Inference의 상호작용형 LLM TTFT 기준 450 ms의 0.0097%로, 두 값은 네 자릿수 이상의 차이를 보인다 [9]. 1 MiB Record의 인코딩·디코딩 처리량은 10.81 GB/s였다. 이 결과는 거버넌스 상태와 암호학적 증거를 통신 프로토콜에 포함하는 데 필요한 핵심 연산 비용이 상호작용형 추론의 지연시간 예산에 비해 작음을 보여준다.

1 서론

다음과 같은 사고를 가정한다. 개발자가 에이전트에게 실패한 권한 부여 테스트의 수정을 요청한다. 에이전트는 저장소 파일 여섯 개를 컨텍스트로 선택하고, “Model A”라는 이름의 모델을 호출한 뒤 셸 도구 제안을 받아 마이그레이션을 실행한다. 이어 두 파일을 수정하고 커밋을 생성한다. 수 시간 후 이 마이그레이션이 테넌트 데이터를 노출했다는 사실이 드러난다. 이때 조직은 다음 질문에 답해야 한다.

- 어떤 인간 사용자와 어떤 설치형 에이전트가 작업을 시작했는가?
- 해당 에이전트는 그 모델에 여섯 개 파일을 공개할 권한이 있었는가?
- 어느 불변 정책 버전이 마이그레이션 명령을 허용했는가?
- 모델은 명령을 제안했을 뿐인가, 아니면 권한을 부여받은 런타임이 이를 실행했는가?
- 어떤 모델 패키지와 서빙 엔드포인트가 제안을 생성했는가?

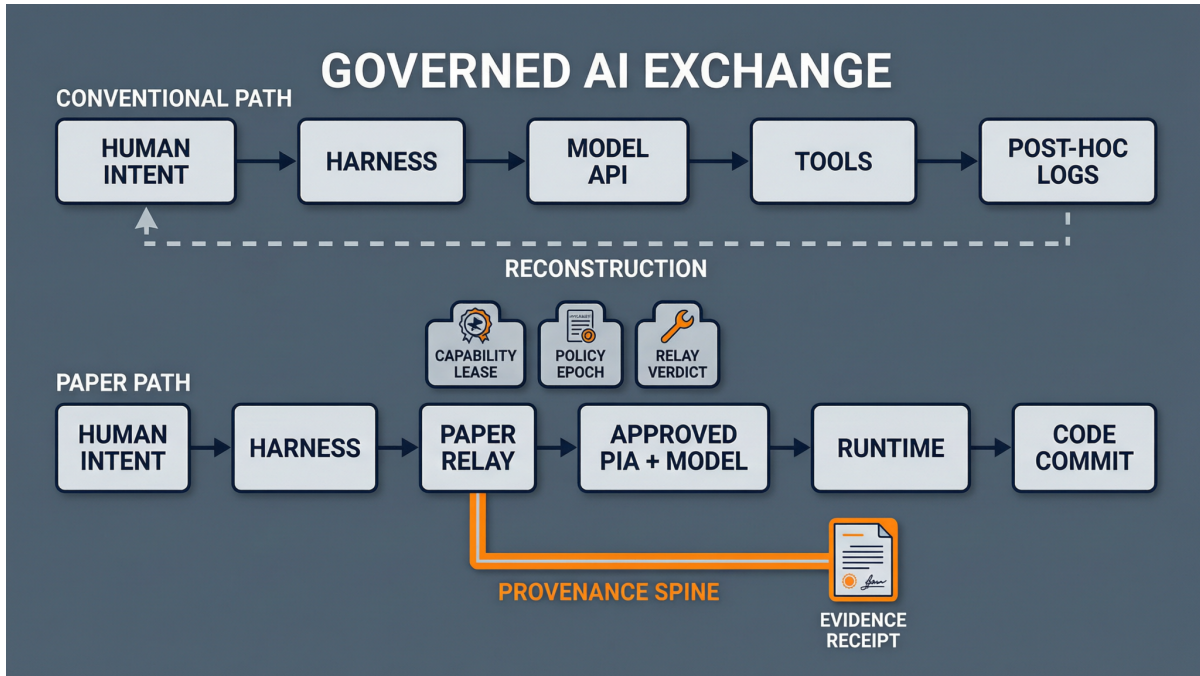


그림 1: 사후 거버넌스와 PAPER의 Governed Exchange 비교. PAPER는 제한된 권한, 정책 집행, 모델 식별, 인과 증거를 실제 처리 경로의 선행 조건으로 표현한다. 본 그림은 개념도이며 측정 데이터를 포함하지 않는다.

- 모델 출력 중 어느 부분이 인간의 수정 이후에도 최종 커밋에 남았는가?

각 구성 요소가 유지하는 로그는 서로 다른 경계를 기술한다. API 인증은 호출자를 식별하고, 게이트웨이는 라우팅이나 정책 판단을 기록하며, 샌드박스는 명령 실행을, Git은 최종 산출물을 기록한다. 하나의 인과관계와 권한 부여 과정을 구성하려면 서로 다른 식별자, 시간 기준, 보존 정책 및 신뢰 가정에 따라 생성된 기록을 상호 연계해야 한다. 기록 사이의 단절이나 모호성은 시스템 변경이 끝난 뒤에야 드러날 수 있다.

이러한 분절은 **프로토콜 모델의 공백**에서 비롯된다. 기존 AI 인터페이스는 프롬프트, 토큰, 도구 호출, 작업, 산출물을 전달하지만, 외부 상태 변경에 적용되는 제한된 권한을 프로토콜 상태로 표현하지 않는다. 그 결과 거버넌스는 상태 전이의 조건이 아니라 외부 미들웨어로 처리된다. PAPER는 신원, 권한, 정책, 인과관계 증거를 추론 및 작업 실행 수명주기에 포함한다.

PAPER는 권한 정보가 결합된 교환을 통해 이 공백을 다룬다. 보호 작업은 신원, 작업 목적, Lease, Policy Epoch, 모델 결정 결과, Relay 판정이 모두 일치할 때에만 다음 상태로 진행한다. TLS 연결의 성립이나 모델이 생성한 도구 호출만으로는 보호 작업을 승인할 수 없다. 그림 1는 이 프로토콜 구조를 요약한다.

1.1 연구 기여

본 논문은 에이전트형 AI 프로토콜이 메시지와 작업을 해당 작업의 권한 정보 및 인과관계 증거와 함께 전달해야 한다는 주장을 검토하며, 다음 네 가지를 기여한다.

1. **Governed Exchange.** 사용자와 피어의 신원, 특정 목적에 한정된 Capability Lease, 변경 불가능한 Policy Epoch, 모델 사용 권한, Relay의 실시간 판정을 보호 작업의 선행 조건으로 정의한다. 모델의 출력은 제안일 뿐이며, 실행 권한은 모델과 분리된 주체가 부여한다.
2. **인과관계가 보존된 권한 체인.** 사용자가 선택한 모델을 서명된 모델 패키지와 유효한 엔드포인트에 연결하고, 작업 의도, 정보 공개, 추론, 도구 사용, 편집, 산출물을 콘텐츠 해시 기반 Provenance Spine과 서명 영수증으로 결합한다. 이를 통해 상태 변경이 어떠한 권한 아래 수행되었는지 검증할 수 있다.

3. **제품 통합형 참조 시스템.** 공식 Patty Code Harness, PAPER Relay, Control Plane 서비스, PIA, 서빙 엔진 어댑터, 런타임 권한, 프로비던스를 잇는 전체 제품 경로를 구현하였다. 공식 Harness는 PAPER를 서비스 추론 제공자로 등록하고 임의 제공자 URL이나 추론 API 키가 아니라 Catalog Model 신원을 전송한다.
4. **개방형 통합 인터페이스.** 누구나 구현할 수 있는 공개 명세, 프로토콜 라이브러리, PIA SDK, 재사용 가능한 vLLM/SGLang 어댑터, 사용자 정의 엔진 인터페이스를 제공한다. 채팅, 코파일럿, 자동화 등 다른 AI 제품도 Patty Code의 응용 로직과 무관하게 동일한 Governed Exchange를 도입할 수 있다.

본 연구의 기여는 기존 구성 요소의 결합과 수명주기 의미론에 있다. PAPER는 보안 전송, Capability, 프로비던스 DAG, 서명 영수증, 도구 프로토콜의 권한 의미를 Harness-Relay-추론/런타임 경계를 아우르는 하나의 실시간 상태 전이 모델로 통합한다. 이 구조에서는 정책을 상태 변경 전에 집행하고 감사 증거를 프로토콜 처리 과정의 산출물로 생성한다.

2 에이전트형 AI 통신의 거버넌스 공백

앞의 사고 사례는 에이전트 시스템에서 반복되는 세 가지 불일치를 드러낸다.

인증은 권한 이력이 아니다. 유효한 API 자격 증명은 요청을 시작한 주체를 식별할 수 있으나, 장시간 이어지는 작업에서 어떤 저장소와 모델을 사용할 수 있는지, 어떤 목적으로 어느 도구를 실행하고 외부 상태를 변경할 수 있는지까지 보여주지는 못한다. 에이전트 작업은 개별 요청보다 오래 지속되며, 서로 다른 권한 모델을 사용하는 여러 구성 요소를 거친다.

모델 출력은 실행 권한이 아니다. 도구 호출 형식은 제한된 행위를 기계 판독 가능하게 만들 뿐 정당하게 만들지는 않는다. 모델이 특정 구문을 출력했다는 이유로 실행이 가능하다면, 신뢰할 수 없는 저장소 텍스트는 프롬프트 인젝션을 통해 권한을 획득하려 할 수 있다. 따라서 집행 경계는 제안, 승인, 실행을 서로 다른 주체가 담당하는 별개의 사건으로 구분해야 한다.

로그는 사건을 기록하지만 단일 인과 경로를 반드시 입증하지는 않는다. 상관 식별자는 유용하지만 상관관계가 프로토콜로 강제된 체인과 동일하지는 않다. “누가 이 커밋을 승인했는가”에 대한 지속 가능한 답은 실행 전에 존재했던 권한 및 정책에 행위를 결합하고, 이후 인간과 자동화 작업을 거치며 결과가 어떻게 변했는지 보존해야 한다.

따라서 보안 전송과 응용별 거버넌스 사이에는 신원, 제한된 권한, 변경 불가능한 정책, 집행 판정, 감사 증거를 하나의 일관된 프로토콜 상태로 관리하는 교환 계층이 필요하다.

3 인접 시스템과 신규성의 경계

모델 API와 게이트웨이. HTTPS/JSON 및 스트리밍 모델 API는 효과적인 요청/응답 인터페이스이며, 게이트웨이는 인증, 할당량, 정책, 로깅을 추가할 수 있다. PAPER의 주된 차이는 상태의 단위이다. 권한과 증거를 독립적인 미들웨어 사건에서 사후 복원하지 않고 장기 거버넌스 세션 및 교환에 결합한다.

MCP와 A2A. Model Context Protocol(MCP)은 AI 응용과 컨텍스트/도구 제공자 간 상호작용을 표준화한다 [10]. Agent2Agent(A2A)는 에이전트 탐색, 작업, 메시지, 아티팩트를 표준화한다 [1]. MCP는 거버넌스형 도구 브로커 뒤에서, A2A는 에이전트 간 경계에서 동작할 수 있다. PAPER는 인간 대상 엔지니어링 Harness, 인라인 정책 집행, 통제된 추론/런타임 인프라, 소프트웨어 프로비던스 사이의 별도 경계를 다룬다.

런타임 거버넌스와 에이전트 보안. MI9은 에이전트 시스템의 통합 런타임 거버넌스를 연구하고 [17], AgentDojo는 프롬프트 인젝션 공격 및 방어 환경을 제공하며 [5], 인자 수준 프로비넌스 연구는 거친 권한 부여와 도구 인자 사이의 불일치를 지적한다 [6]. PAPER는 이에 상보적이며, 신원, 정책, 도구 권한, 증거를 집행하고 반출할 수 있는 프로토콜 객체와 상태 전이를 정의한다.

공급망 프로비넌스. in-toto는 공급망 각 단계의 서명 메타데이터를 기록하고 [7, 16], SLSA는 빌드 및 소스 프로비넌스의 기대 수준을 정의한다 [13]. SCITT는 디지털 산출물에 관한 서명된 진술을 등록하고 영수증을 발급하는 투명성 서비스를 정의한다 [3]. PAPER는 빌드 산출물이 만들어지기 전의 상호작용 단계에서 컨텍스트 공개, 모델 추론, 외부 상태 변경의 허용 여부를 통제한다. PAPER 영수증은 이후 in-toto/SLSA 증명의 입력이나 SCITT 진술로 사용할 수 있지만, 산출물 투명성만으로 실시간 교환의 권한 검증을 대신할 수는 없다.

신원 및 암호학적 구성 요소. SPIFFE는 워크로드 신원 규약을 제공한다 [14]. PAPER는 TLS 1.3 [11], QUIC [8], 결정적 CBOR [4], COSE [12], HPKE [2], COSE 영수증 [15]을 재사용한다. 이 표준들은 전송 및 객체 보안의 기반을 제공하지만 본 연구가 제안하는 응용 수준 권한 모델을 정의하지는 않는다.

각 인접 기술의 역할은 신규성의 경계를 구분한다. MCP는 도구를 기술하고, A2A는 에이전트 간 작업을 표현하며, SPIFFE는 워크로드를 식별하고, 게이트웨이는 정책을 집행하며, in-toto는 공급망 단계를 증명한다. PAPER는 제안된 계산이 권한 있는 지속적 상태 변경으로 전환되는 지점에서 이 요소들을 하나의 거버넌스 상태 전이 모델로 결합한다.

4 요구사항과 위협 모델

4.1 설계 요구사항

사고 사례에서 제기된 질문은 여섯 가지 프로토콜 요구사항으로 정리할 수 있다. (R1) 모든 보호 작업을 등록 피어와 실제 사용자 신원에 연결한다. (R2) 유효기간과 목적이 제한된 권한으로 허용 범위를 통제한다. (R3) 모든 집행 판정을 변경 불가능한 정책 개정본에 연결한다. (R4) 호출자가 임의로 제공한 이름이 아니라 검증 가능한 방식으로 모델 아티팩트와 실행 엔드포인트를 식별한다. (R5) 모델의 작업 제안과 런타임의 승인·실행을 분리한다. (R6) 일반 응용 로그와 독립적으로 보존 가능한 인과관계 증거를 생성한다.

시스템은 제어 평면이 일시적으로 가용하지 않은 상황에서도 동작해야 한다. 따라서 Relay는 서명 또는 인증된 스냅샷, 폐기 상태, Policy Epoch, 모델 카탈로그, Lease를 소비한다. 오래된 상태를 사용할 수 있는 범위는 암묵적 캐시 동작이 아니라 명시적 만료 및 배포 정책으로 제한한다.

4.2 공격자와 비목표

네트워크 공격자, 미등록 클라이언트, 탈취·재생된 자격 증명, 침해된 Harness, 프롬프트 인젝션 콘텐츠, 악성 도구 출력, 모델명 위조, 테넌트 간 오조작, 증거 변조를 고려한다. Relay 또는 관리자 역시 악의적이거나 침해될 수 있다. 프로토콜은 권한과 증거의 경계를 명시하는 것을 목표로 하지만, 평문을 처리하는 신뢰 Relay의 열람을 막거나 모델의 올바른 행동을 증명하거나 완전히 침해된 엔드포인트의 프로토콜 외부 행위를 막지는 못한다. 하드웨어 증명과 형식 검증은 선택 가능한 보증 프로파일이며 핵심 프로토콜의 필수 가정은 아니다.

5 Governed Exchange

Governed Exchange는 PAPER에서 하나의 AI 작업에 대한 책임 관계를 추적하는 기본 단위이다. 범위는 개별 API 요청보다 넓지만 전체 개발 세션보다는 좁다. Harness가 보호 대상 작업의 목적을 선언할 때 시작하며, 처리

표 1: 핵심 권한 및 신원 객체. Harness에 노출되는 객체와 배포 신원을 의도적으로 분리한다.

객체	발급 주체	목적	핵심 구분
Peer credential	등록 기관	키, 피어 프로파일, 테넌트, 유효기간 결합	사용자뿐 아니라 소프트웨어 인스턴스 식별
Capability Lease	정책 관리 주체	작업·모델·도구·컨텍스트 범위의 제한적 부여	자원 용량이 아니라 작업 권한
Policy Epoch	정책 관리 주체	적용 정책의 변경 불가능한 개정본	“최신 정책”이 아니라 특정 다이제스트에 연결
Catalog Model	모델 카탈로그	사용자에게 보이는 안정적 서비스 신원	제공자 엔드포인트를 포함하지 않음
Model Descriptor	모델 카탈로그	의미 기능 및 최소 클라이언트 요건 선언	협상 정보이며 그 자체가 권한은 아님
Model Package (PMP)	모델 관리 주체	서명된 아티팩트·템플릿·양자화 구성 식별	사람이 읽는 모델정보보다 강한 식별
Endpoint Lease	서빙 관리 주체	활성 PIA 엔드포인트와 승인 패키지 결합	단기 배포 상태
Account Capacity Lease	용량 관리 주체	분산 워크로드 슬롯 조정	작업 권한과 구별되는 자원 용량

결과와 증거를 확정하는 영수증이 발급되면 종료된다. 이 범위 안에서 추론, 컨텍스트 공개, 모델 선택, 도구 사용, 승인, 출력은 권한 검증을 포함한 상태 전이로 처리된다.

이를 데이터베이스 일관성 대신 거버넌스 요건의 충족을 완료 조건으로 삼는 트랜잭션으로 이해할 수 있다. TLS가 데이터가 보호된 채널로 전달되었는지를 보장한다면, Governed Exchange는 요청 주체, 작업 목적, 적용 정책, 사용할 모델, 예정된 시스템 변경이 서로 부합하는지까지 확인한다. 필수 검증을 통과하지 못한 작업은 실행을 차단하며, 사후 로그 기록으로 이를 대신하지 않는다.

5.1 아키텍처와 피어

관리 Control Plane은 신원을 등록하고 정책과 모델 정보를 배포하며, 자격 증명 폐기 상태를 관리하고 감사 증거를 색인한다. 전체 시스템의 기준 정보를 관리하지만 모든 토큰 처리 경로에 동기식으로 참여하지는 않는다. Relay는 Harness 연결을 종단하고 캐시된 서명 정보를 검증한 뒤, 실시간 정책 판정, 승인된 추론의 라우팅, 증거 기록을 수행한다. Patty Inference Agent(PIA)는 서빙 엔진 앞에 배치되는 등록 피어이다. PIA는 PAPER의 공통 요청 형식을 로컬 엔진 인터페이스로 변환한다. 따라서 Harness가 원시 모델 엔드포인트를 직접 선택하거나 신뢰 경로로 사용할 수 없다. 런타임 역시 별도의 권한 검증이 완료된 후에만 도구를 실행한다.

5.2 프로토콜 집행과 사후 로깅

로그 스키마는 허용 판정을 기록하지만, 정보 공개, 모델 배정, 도구 실행에 앞서 권한 판정이 이루어지도록 강제할 수는 없다. PAPER는 신원 연결, Lease 제출, Policy Epoch 확정, Relay 판정, 요청 전달, 도구 승인, 교환 종료를 순서가 정해진 프로토콜 상태 전이로 표현한다. 피어는 보호 작업을 진행하기 전에 이러한 전이를 완료해야 하므로, 프로토콜 집행과 사후 미들웨어 기록이 구분된다.

교환 x 에서 시각 t 에 보호 행위 a 가 시도된다고 하자. PAPER는 다음 조건이 성립할 때에만 해당 상태 전이를 허용한다.

$$\text{advance}(x, a, t) = P_x \wedge S_x \wedge L_x(a, t) \wedge E_x \wedge V_x(a) \wedge R_x(a), \quad (1)$$

여기서 P_x 와 S_x 는 각각 유효한 피어 및 세션 연결을, $L_x(a, t)$ 는 작업 a 를 허용하며 아직 만료되지 않은 Capability Lease를 나타낸다. E_x 는 시스템이 인식하는 변경 불가능한 Policy Epoch, $V_x(a)$ 는 Relay가 내린 허용 판정이다. $R_x(a)$ 는 작업 종류에 따라 추가로 요구되는 권한 조건을 묶어 표현한다. 추론에는 승인된 모델 패키지와 유효한 Endpoint Lease가 필요하고, 외부 상태를 변경하는 작업에는 별도의 도구 실행 권한이 필요하다. 식 1은 프로토콜의 수락 조건을 나타낼 뿐 형식적 보안 증명은 아니다. 어느 조건 하나라도 충족되지 않으면 해당 상태 전이는 차단된다.

5.3 전송과 표현

독립 스트림을 지원하는 QUIC은 head-of-line blocking의 영향을 줄일 수 있으므로 기본 전송 방식으로 사용하고, TLS 1.3 over TCP를 대체 경로로 제공한다. 두 전송 방식은 동일한 응용 계층 의미와 ALPN 식별자를 사용한다. Record는 고정 길이 prelude, 표준화된 헤더, payload, 논리 lane 식별자, lane sequence로 구성된다. 결정적 CBOR은 동일한 객체가 항상 같은 바이트열로 인코딩되도록 하며, 자격 증명, Lease, Epoch, 모델 manifest, 영수증처럼 객체 자체의 검증이 필요한 데이터는 COSE 서명으로 보호한다.

응용 인증은 피어 자격 증명, nonce, 협상 프로파일, 채널 문맥을 결합하여 한 연결에서 캡처한 증명을 다른 연결에서 재생하지 못하게 한다. PAPER는 관련 메시지를 정의하고 제품 경로는 handshake를 수행한다. 절 8에서는 로컬 개발용 자격 증명 프로파일과 조직 발급 자격 증명, 폐기 상태, transcript 결합 검증을 사용하는 배포 프로파일의 보증 수준을 구분한다.

6 권한 기반 상태 전이

6.1 신원, 세션, Capability Lease

사용자 신원, Harness 신원, 워크로드/세션 신원은 서로 다른 질문에 답하므로 분리한다. 즉 누가 작업을 요청했는지, 어느 소프트웨어 인스턴스가 요청을 전달했는지, 현재 어떤 범위의 작업이 진행 중인지를 각각 식별한다. Harness 등록은 피어 자격 증명을 발급할 뿐 모델 호출이나 도구 실행 권한까지 부여하지 않는다. Working Session은 사용자, Harness, 조직 또는 프로젝트, 작업 목적, 저장소, 적용 정책을 하나로 연결한다. Capability Lease는 사용할 수 있는 모델, 공개 가능한 컨텍스트 경로, 도구 종류, 토큰 예산, 승인 조건 등을 제한된 기간 동안 허용한다. 전송 연결이 유지되고 있더라도 Lease가 폐기되거나 만료되면 새로운 보호 작업은 시작할 수 없다.

6.2 Policy Epoch과 Relay Verdict

Policy Epoch은 해당 교환에서 무엇을 “허용”으로 판단했는지를 고정한다. 감사 시점의 최신 정책을 가리키는 참조가 아니라, 다이제스트로 식별되는 변경 불가능한 정책 스냅샷이다. 세션 도중 정책이 변경되더라도 이미 시작된 작업은 사전에 정한 규칙에 따라 계속, 재검증, 일시정지, 종료 중 하나로 처리되며, 과거 판정의 의미가 새 정책에 맞춰 소급 변경되지 않는다. 보호 대상 데이터가 PIA나 런타임에 전달되기 전에 Relay는 허용, 거부, 변환, 격리, 추가 승인 요구 등의 구조화된 판정을 내리고, 적용한 Epoch과 규칙 집합을 함께 기록한다.

6.3 교환 수명주기

일반적인 교환은 OPEN, GOVERNANCE, ROUTE, STREAM, 선택적 TOOL/APPROVAL, CLOSE 순으로 진행한다. 이 명칭들은 단순한 설명용 단계가 아니라, 각 시점에 허용되는 메시지 종류를 제한하는 실제 프로토콜 상태이다. Relay는 요청을 전달하기 전에 피어와 세션의 연결 관계, Capability Lease, Policy Epoch, Catalog Model, Model Package, Endpoint Lease, 가용 자원 정보를 검증한다. 토큰과 데이터 Record는 각각 순번이 부여된 lane을 통해 다중화된다. 외부 상태를 변경하는 작업에는 먹등성 등급을 지정하여 연결 복구나 세션 재개 과정에서 이미 완료된 작업이 다시 실행되지 않도록 한다.

앞의 사고 사례에서는 여섯 파일이 Harness를 떠나기 전에 Lease와 Epoch에 따라 공개 여부를 결정한다. “Model A”는 추론 전에 서명 패키지와 Lease가 있는 PIA 엔드포인트로 해석된다. 셀 문자열은 별도로 권한을 받은 런타임 전이가 실행할 때까지 제안으로 남는다. 최종 영수증은 이 판단들을 이후 커밋에 연결되는 증거 루트에 결합한다. 그림 2는 이 순서를 나타낸다. 도구가 제안되는지는 선택적이지만, 제안된 도구의 권한 부여는 선택 사항이 아니다.

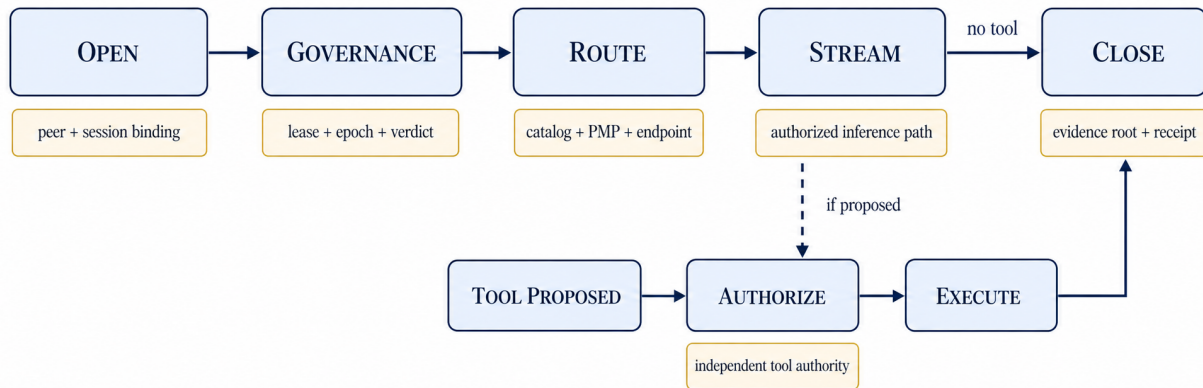


그림 2: Governed Exchange의 프로토콜 설계. 보호 작업은 순차적 권한 게이트를 통과한다. 모델이 도구를 제안할 수는 있으나 실행 전에 독립적인 권한 전이가 반드시 필요하다. 본 그림은 의도한 의미를 설명하며 구현 범위를 측정한 결과가 아니다.

6.4 서버가 주도하는 모델 결정

PAPER는 사용자에게 표시되는 모델명과 보안 식별 정보를 구분하며, 다음 세 식별자를 별도로 관리한다.

Catalog Model → PMP → PIA Endpoint.

인증 후 Harness는 권리, 조직 정책, 배포 프로파일, 지역, 클라이언트 기능에 맞게 제한된 유효 모델 카탈로그를 받는다. Model Descriptor는 멀티모달 입력, 구조화 출력, 병렬 도구, 캐시, 추론 제어, 재개 가능성과 같은 의미 기능을 광고하되 엔드포인트를 공개하지 않는다. inference-open 메시지는 Catalog Model과 Catalog Epoch을 참조한다. Relay는 오래되거나 허용되지 않은 선택을 거부하고, 서명된 Patty Model Package(PMP)를 해석한 뒤 유효한 Lease가 있는 PIA 엔드포인트를 선택한다. Catalog Model은 사용자에게 보이는 안정적 제품 신원, PMP는 승인된 아티팩트 및 서빙 구성, Endpoint Lease는 해당 패키지가 현재 실행될 수 있는 위치를 뜻한다. 호출자는 선호를 표현할 수 있지만 문자열이나 base URL을 신뢰 인프라로 바꿀 수 없다.

그림 3는 사용자에게 표시되는 모델명이 실제 라우팅 대상을 임의로 결정하지 못하도록 세 가지 식별 정보를 분리하는 방식을 보여준다.

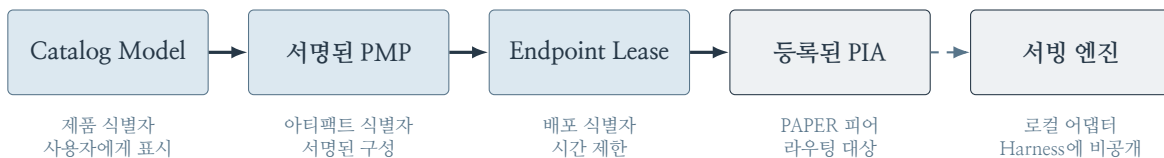


그림 3: 서버가 주도하는 모델 결정 과정. 서비스 모델, 모델 아티팩트, 실행 위치는 Relay가 등록된 PIA를 선택할 때까지 별개의 식별 정보로 유지된다. 서빙 엔진은 로컬 구현 요소이며 Harness가 직접 선택할 수 있는 엔드포인트가 아니다.

6.5 도구 권한과 프롬프트 인젝션

PAPER는 프롬프트 인젝션으로 생성된 출력에도 모델 출력은 제안이지 권한이 아니다라는 규칙을 적용한다. Tool Descriptor는 실행 위치, 위험 등급, 인자 스키마, 승인 정책, 맥등성, 프로비넌스 요건을 지정한다. 스트리밍 중인 인자는 완전한 형태로 수신되고 권한이 확인되기 전까지 실행할 수 없다. 저장소 텍스트, 채팅, 파일, 도구 출력은 신뢰 레이블을 유지하지만 Lease 범위를 확장할 수 없다. 따라서 주입된 텍스트는 독립적으로 통제되는 권한 경계를 통과해야 한다. PAPER는 제안과 그 실행을 허용·변환·거부한 판단을 모두 기록한다.

7 인과 프로비넌스와 영수증

감사의 목적은 특정 권한 아래 산출물이 생성된 과정을 확인하는 데 있다. Provenance Spine은 사용자의 작업 의도, 선택한 컨텍스트, 정책 판정, 모델 호출과 출력, 도구 제안과 승인, 실행 결과, 코드 편집, 테스트, 검토, 소스 제어 산출물 사이의 인과관계를 표현한다. 각 노드는 콘텐츠 해시와 유형으로 식별되며, 간선은 원인, 파생, 공개, 변환, 연결 관계를 나타낸다. 프로토콜이 요구하는 상태 전이가 누락되면 전체 인과관계에서 검증 가능한 단절이 발생한다. 거버넌스 경로 밖에서 수행된 작업은 영수증의 관측 범위에 포함되지 않는다.

교환 무결성을 간결하게 표현하기 위해 $r_0 = H(\text{domain} \parallel \text{exchange-open})$ 으로 두고 다음과 같이 정의한다.

$$r_i = H(\text{domain} \parallel r_{i-1} \parallel H(e_i)), \quad (2)$$

e_i 는 i 번째 증거 사건을 표준 형식으로 표현한 값이다. 서명된 Evidence Receipt는 최종 루트 해시를 교환 식별자, 관련 신원, Policy Epoch, 모델 및 패키지 결정 결과, 작업 결과, 보존·반출 정책과 연결한다. 전체 사건을 순서대로 확보한 감사자는 루트 해시를 다시 계산하여 종료된 교환 기록과 일치하는지 검증할 수 있다. 사건 중 일부만 선택적으로 공개하면서 포함 여부까지 증명하려면 별도의 commitment 또는 inclusion proof가 필요하며, 현재의 체인 갱신 연산만으로는 이를 제공하지 않는다.

이 구조는 명시된 구성 요소 신뢰 가정 아래 변조 여부를 검증한다. 침해된 권한 구성 요소는 거짓 원천 데이터를 낼 수 있고, 모든 서명자를 통제하는 공모 집단은 일관된 허위 기록을 만들 수 있다. 구성 요소 간 영수증과 외부 투명성은 단일 주체에 대한 신뢰를 줄이지만 원천 사건의 사실성을 확립하지는 않는다. 따라서 암호학적 무결성과 의미적 진실성은 서로 다른 속성으로 다룬다.

선택적 반출 프로파일은 민감한 노드를 commitment 또는 비식별 요약으로 대체할 수 있으나, 검증 가능한 연결은 현재 체인 벤치마크가 입증한 성질이 아니라 설계 요구사항이다. 리팩터링이나 병합 이후의 소스 코드 귀속은 확률적으로 다루고, 이진 “AI 생성” 레이블 대신 신뢰도와 변환 이력을 제시해야 한다.

8 개방형 명세에서 통합 제품으로

PAPER는 공개 명세로 제공되며 PCCP 제품군의 통신 기반으로 구현되어 있다. 구현 범위는 32바이트 Record prelude, 크기가 제한된 헤더와 payload, 결정적 CBOR, COSE Sign1, Ed25519 객체 서명, 콘텐츠 해시, 증거 체인, 피어 및 세션 상태 전이, TLS/TCP와 QUIC 바인딩, 모델·카탈로그 스키마, 정책과 Lease 서비스, Relay와 PIA, 프로비넌스, 프로토콜 레지스트리, 적합성 검사, 배포 manifest를 포함한다. 벤치마크는 저장소 커밋 0234034에서 수행하였으며, 아래에서 설명하는 제품 통합은 그 이후 Patty Code와 PCCP 사이에 완성된 경로를 반영한다.

8.1 Patty Code 통합

공식 Patty Code Harness는 PAPER를 서비스 추론 제공자로 등록한다. Harness 프로파일로 연결을 시작하고 Relay의 challenge를 받은 뒤 인증 정보를 전송하며, AI_OPEN, 스트리밍 토큰 Record, AI_COMPLETE 메시지를 통해 추론을 수행한다. 공식 빌드는 Patty 서비스 추론을 위한 범용 OpenAI, Anthropic, Responses 계열 제공자를

표 2: 구현된 제품 구성과 본 논문에서 제시하는 검증 자료. 기능의 제공 여부와 측정 범위를 구분하였다.

제품 구성	상태	통합 근거	본 논문의 주장 범위
개방형 PAPER 코어	제공	명세, 프로토콜 라이브러리, 레지스트리, 전송 및 객체 테스트	구현된 프로토콜과 재사용 가능한 라이브러리
공식 Patty Code Harness	통합	PAPER 전용 제공자 등록과 Harness 프로토콜 클라이언트	Patty Code가 서비스 추론에 PAPER를 사용
Relay와 Control Plane	통합	신원, 카탈로그, 정책, Lease, 라우팅, 감사, 프로비넌스 서비스	제품 거버넌스 경로가 존재하며 보증은 배포 프로파일에 의존
PIA와 서빙 엔진	제공	PAPER PIA 및 재사용 가능한 vLLM/SGLang 어댑터	Harness에 엔드포인트 권한을 주지 않고 엔진 통합 가능
SDK와 사용자 응용	제공	PIA SDK, 예제, 사용자 정의 EngineAdapter	채팅, 코파일럿, 자동화, 사용자 정의 AI 제품에 적용 가능
증거와 프로비넌스	통합	ChangeSet, span, chain, receipt, 감사 서비스	명시한 신뢰 가정 아래 인과관계 증거를 제품이 직접 생성
측정된 핵심 연산	측정	체크인된 벤치마크 데이터의 5회 중앙값	지연시간, 처리량, 메모리 할당량, 상호작용 지연 예산 대비 비율
보증 프로파일	프로파일별	적합성 감사와 명시적 보증 행렬	배포 요건과 검증 수준을 명시적으로 제시

등록하지 않는다. Harness는 서버가 배포한 Catalog Model을 선택하며, 임의의 base URL이나 추론 API 키는 라우팅 권한으로 사용되지 않는다. 이 제약은 현재의 제공자 등록과 프로토콜 클라이언트에서 적용된다.

Relay는 거버넌스 요건을 적용해 요청을 심사하고, 승인된 추론 요청을 PAPER 연결을 통해 PIA로 전달한다. PIA는 공통 형식의 요청을 로컬 서빙 엔진이 이해하는 형식으로 변환하고, 텍스트, reasoning, 도구 호출, 사용량, 완료 정보를 다시 공통 형식으로 반환한다. 동일한 Harness 런타임은 저장소 접근, 승인 모드, 샌드박스 도구, 세션 복구, MCP 도구, Skill, subagent, 편집기 연동을 제공한다. 이에 따라 PAPER는 통합 코딩 에이전트 제품의 운영 수명주기 안에서 사용된다.

8.2 응용 중립적 통합

PAPER의 AI 메시지 형식은 특정 응용에 종속되지 않는다. 다중 턴 대화, 스트리밍, 도구 정의와 호출, 구조화 출력, 멀티모달 입력, 캐시 제어, compaction을 공통 형식으로 표현한다. 채팅 응용은 대화와 스트리밍 기능만 사용할 수 있고, 코파일럿은 여기에 컨텍스트와 도구 권한을 추가할 수 있으며, 자동화 시스템은 외부 상태 변경과 감사 증거까지 연결할 수 있다. 어떤 경우에도 Patty Code의 저장소 처리 기능이나 사용자 인터페이스를 함께 도입할 필요는 없다.

외부 개발자를 위한 통합 수단으로 프로토콜 라이브러리, PIA SDK와 예제, 재사용 가능한 vLLM/SGLang 어댑터, 사용자 정의 런타임용 **EngineAdapter** 인터페이스를 제공한다. PIA는 서빙 엔진이 독립적으로 발전하더라도 일관된 신뢰 경계를 유지한다. `Relay <-> PAPER <-> PIA <-> local engine` 구조를 사용하므로 vLLM이나 SGLang을 별도로 fork하지 않고도 상용 및 오픈소스 AI 응용에 PAPER를 연동할 수 있다.

9 평가 질문과 기준선

평가는 거버넌스 집행과 상호작용 성능의 관계를 다룬다. 구체적인 질문은 다음과 같다. (Q1) PAPER가 연결 및 추론 전 지연에 추가하는 비용은 얼마인가? (Q2) 스트림 증가에 따라 Relay 비용은 어떻게 변하는가? (Q3) 검증 가능한 인과 경로에 수반되는 증거 및 저장 비용은 얼마인가? (Q4) 프로토콜 상태가 거부하는 적대 사례는 무엇인가? (Q5) 실제 소프트웨어 변경 이후 프로비넌스는 얼마나 정확하게 유지되는가?

9.1 기준선

목표에 맞춘 다섯 기준선을 정의한다. B0는 최소 보안 이진 스트림, B1은 bearer 인증 HTTPS/JSON 스트리밍, B2는 동등한 게이트웨이 정책 및 로깅을 더한 HTTPS/JSON, B3는 신원/세션 및 최소 거버넌스를 적용한 PAPER, B4는 Lease, 정책, 콘텐츠 검사, Verdict, 프로비던스를 적용한 PAPER이다. 주된 비교는 동등한 거버넌스와 다른 수명주기를 비교하는 B2 대 B4, 그리고 거버넌스의 한계 비용을 비교하는 B3 대 B4이다. MCP와 A2A는 성능 기준선이 아니라 의미론적으로 인접한 프로토콜로 다룬다.

종단 간 실험은 연결 p50/p95/p99, 첫 Relay Verdict까지의 시간, TTFT, 토큰 간 지연, 지속 처리량, CPU 시간, 할당량, 스트림당 메모리, 증거 바이트를 보고해야 한다. 환경에는 CPU, 메모리, NIC, RTT, 토폴로지, OS, 런타임 및 전송 라이브러리 버전, 모델/양자화, GPU, 정책 모듈, 저장 백엔드를 포함해야 한다.

9.2 보안 및 프로비던스 실험

보안 부정 테스트에는 미등록 피어, 만료되거나 재사용된 Lease, 시스템에 등록되지 않은 Policy Epoch, 오래된 카탈로그, 미승인 Model Package, 유효하지 않은 Endpoint Lease, 피어 프로파일에 허용되지 않은 메시지, 잘못된 상태 전이 순서, 세션 재개 후 동일 작업의 중복 실행, 프롬프트 인젝션을 통한 권한 상승, 변조된 영수증이 포함된다. 프로비던스의 정확성은 모델이 생성한 함수에 사람이 추가 편집을 수행하고, 파일명 변경, 함수 이동, rebase, merge, 다중 에이전트 수정을 적용한 뒤 측정해야 한다. 일부 사례만 제시하기보다 정밀도, 재현율, 신뢰도 보정을 함께 보고하는 것이 적절하다.

10 시스템 핵심 연산 측정

10.1 실험 환경

본 논문은 PAPER의 프레이밍, 암호, 증거 연산이 네트워크 또는 모델 처리 시간에 가려지지 않도록 각 비용을 분리해 측정하였다. Apple M4 Pro, 논리 CPU 14개, RAM 48 GiB, macOS 27.0, arm64 환경에서 로컬 측정하였고, 각 벤치마크를 5회 반복하여 중앙값을 산출하였다. 이 결과는 B0–B4 시스템 비교를 위한 재현 가능한 하위 계층 기준선을 제공한다.

연산 o 에 대해 보고하는 지연은 다음과 같다.

$$\tilde{t}_o = \text{median} \{t_o^{(1)}, t_o^{(2)}, \dots, t_o^{(5)}\}. \quad (3)$$

아티팩트에는 $\tilde{t}_o$ 만 보존하였다. 다섯 개별 관측값은 남아 있지 않으므로 산포, 신뢰구간, 통계적 유의성을 보고하지 않는다.

1 MiB payload의 Record 인코딩·디코딩 시간은 $97.0 \mu\text{s}$ 였으며, 고정 비용이 분산되면서 측정한 세 가지 크기에서 바이트당 처리 시간이 감소하였다. Record payload 크기를 s 라 할 때 바이트당 비용과 유효 payload 처리량을 다음과 같이 정의한다.

$$c(s) = \frac{\tilde{t}_{\text{record}}(s)}{s}, \quad q(s) = \frac{s}{\tilde{t}_{\text{record}}(s)}. \quad (4)$$

$c(s)$ 는 1 KiB에서 0.283 ns/byte, 1 MiB에서 0.0925 ns/byte로 감소하며, 이에 대응하는 $q(s)$ 는 3.53에서 10.81 GB/s(10.1 GiB/s)로 증가한다. 증거 체인 갱신 73.05 ns는 증거 사건마다 적용 가능한 수준이고, 서명 및 검증 42.7 μs 는 교환 또는 영수증 경계에 실용적으로 적용할 수 있는 수준이다.

표 3: 5회 실행 중앙값으로 산출한 메모리 내 시스템 핵심 연산. Record 테스트는 인코딩과 디코딩을 포함한다.

연산	시간/op	B/op	할당 횟수
Record, 1 KiB	290.2 ns	2,384	7
Record, 64 KiB	8.46 μ s	139,472	7
Record, 1 MiB	97.0 μ s	2,105,556	7
CBOR Hello 왕복	599.4 ns	592	9
증거 체인 갱신	73.05 ns	32	1
1 KiB 객체 다이제스트	403.1 ns	32	1
Ed25519 서명+검증	42.7 μ s	64	1

개별 수치의 의미를 상호작용형 AI의 지연시간과 연결하기 위해, Governed Exchange 수명주기에서 사용하는 네 핵심 연산, 즉 1 KiB Record 왕복, 증거 체인 갱신, 객체 다이제스트, Ed25519 서명 및 검증으로 비교 묶음을 구성하였다. 각 연산의 측정값을 산술적으로 합한 결과는 다음과 같다.

$$L_{\text{PAPER},1\text{KiB}} = 0.2902 + 0.07305 + 0.4031 + 42.688 = 43.45435 \mu\text{s}. \quad (5)$$

MLPerf Inference는 Llama 2 70B의 상호작용형 서비스에 99백분위수 TTFT 450 ms 기준을 적용한다 [9]. 이 기준에 대한 PAPER 핵심 연산 묶음의 비율은

$$\rho = \frac{L_{\text{PAPER},1\text{KiB}}}{450 \text{ ms}} = 9.66 \times 10^{-5} = 0.0097\% \quad (6)$$

이다. 기준 지연시간은 합산한 핵심 연산 비용보다 10,000배 이상 크다. 이 묶음의 98.2%는 Ed25519 서명 및 검증이 차지하며, PAPER의 Record 처리, 다이제스트, 증거 체인 연산은 나머지 0.77 μ s를 차지한다. 따라서 측정된 핵심 연산 비용은 비교에 사용한 상호작용형 LLM 지연시간 예산보다 네 자릿수 이상 작다.

메모리 비용을 분리하기 위해 Record 벤치마크 한 회의 할당 바이트를 $B_{\text{op}}(s)$ 라 하고 할당 증폭을 다음과 같이 정의한다.

$$A(s) = \frac{B_{\text{op}}(s)}{s}. \quad (7)$$

$A(s)$ 는 1 KiB에서 2.33, 1 MiB에서 2.01로 감소한다. 매 반복에서 인코딩 버퍼와 디코딩 Record를 모두 할당하므로 큰 payload의 할당량은 payload 크기의 약 두 배이며, 이는 구체적인 최적화 대상이다.

그림 4는 네 자릿수 범위의 차이를 로그 척도로 보이며, 표 3가 정확한 수치의 기준이다.

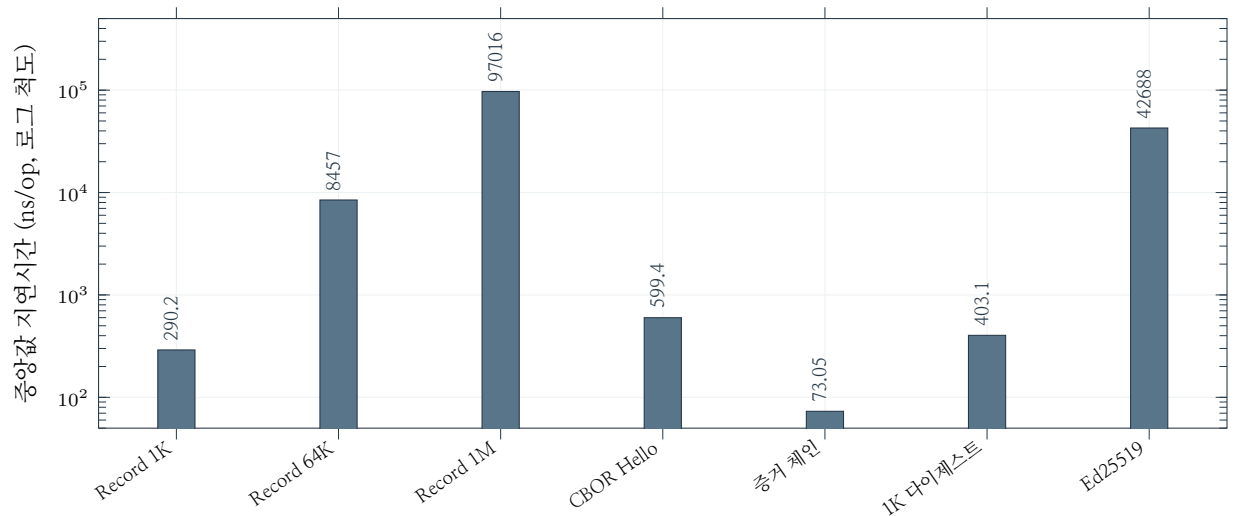


그림 4: 저장소의 TSV 데이터에서 산출한 일곱 가지 메모리 내 핵심 연산의 중앙값 지연시간. 로그 척도를 사용하였으며, 분리 측정된 CPU 비용을 식 6의 상호작용 지연 예산과 직접 비교할 수 있다.

이들 핵심 연산은 표준 형식의 증거 생성, 색인, 보존, 서명 영수증을 구성하는 반복적인 기반 연산이다. 추가적인 메모리 할당 최적화를 적용하기 전에도 1 KiB 연산 묶음은 상호작용형 TTFT 기준의 1만분의 1 미만을 사용하므로, 정책 평가, 전송, 저장, 모델 서버에 충분한 지연시간 여유를 남긴다.

평가 커밋에서는 전체 저장소 테스트가 통과하였다. 별도의 범위 감사 결과, 일부 적합성 테스트의 이름이 실제 검증식보다 넓은 속성을 나타내는 것으로 확인되었다. 불변조건 1-5와 7-12의 이름을 가진 테스트 11개가 있으며 6에 해당하는 테스트는 없다. 일부 통과 테스트는 이름이 나타내는 속성의 대리 지표만 검사한다. 예를 들어 Policy Epoch 테스트는 알 수 없는 Epoch의 거부가 아니라 연결 준비 상태를 확인하고, 재연결 테스트에는 검증식이 없다. 이에 따라 저장소 테스트 통과 여부와 불변조건 검증 범위를 구분하여 보고한다. 상세 분석 결과는 부록 A에 제시한다.

10.2 해석

비교 연산 묶음은 상호작용형 LLM 지연 기준의 0.0097%를 차지하고, 대용량 Record 처리량은 10 GiB/s를 넘는다. 이 측정값은 TLS/QUIC 연결, 정책 모듈, 데이터베이스 및 캐시 접근, 콘텐츠 분류기, 네트워크 구성, 모델 스케줄링, 증거 저장에 사용할 수 있는 지연시간 예산이 충분히 남아 있음을 나타낸다. B0-B4 실험은 이러한 시스템 수준 구성 요소를 정량화하고, 보안 부정 테스트는 PAPER의 권한 모델이 Relay의 거부 동작으로 이어지는지를 평가한다.

11 비교 범위

표 4는 기여의 범위를 하위 메커니즘이 아니라 조합과 수명주기 의미론에 둔다. 기존 게이트웨이는 PAPER의 개념 상당수를 구현할 수 있으므로, 경험적 구분점은 배포별 미들웨어와 공유 프로토콜 상태가 상호운용성, 권한 공백, 실패 동작에서 서로 다른 결과를 만드는지에 있다. B2-B4 비교는 이 차이를 측정하도록 설계하였다.

12 모델과 실행 권한을 분리했을 때의 보안 효과

PAPER는 모델을 신뢰할 수 없는 주체로 취급하고 모델 출력 채널을 통해 행사할 수 있는 권한을 제한한다. 등록되지 않은 일반 클라이언트에는 유효한 피어 자격 증명과 세션 권한이 없다. Harness 키가 탈취되더라도 Lease

표 4: PAPER와 인접 시스템 계열의 적용 범위를 정렬한 정성 비교.

시스템 계열	주된 경계	실시간 목적 한정 권한	인라인 모델/패키지 신원	상호작용형 코드 인과 프로비넌스
Model API	응용 - 모델 서비스	일반적으로 응용에서 정의	대개 호출자에게 보이는 모델 식별자	외부 시스템
AI gateway	응용 - 제공자 중재	게이트웨이/정책에 의존	제공자 라우트에 의존	로그/플러그인
MCP	AI 응용 - 도구/컨텍스트 제공자	배포별 권한 설정에 의존	지원 범위 밖	지원 범위 밖
A2A	에이전트 - 에이전트 작업/아티팩트 교환	프로토콜 및 작업 설정	지원 범위 밖	지원 범위 밖
in-toto/SLSA	공급망 단계/아티팩트	단계/빌드 정책	아티팩트 신원	단계/빌드 이후 프로비넌스
PAPER	Harness - Relay - PIA/ runtime	Capability Lease + Policy Epoch	Catalog Model + PMP + Endpoint Lease	교환 그래프/영수증에 내재

의 유효기간, 저장소와 작업 목적의 범위, 폐기 상태, 선택적 장치 증명에 따라 사용할 수 있는 권한이 제한된다. Relay가 승인된 Catalog Model을 서명된 PMP와 활성 Endpoint Lease를 통해서만 실제 엔드포인트로 연결하면, 위조된 모델명만으로 실행 위치를 선택할 수 없다. 프롬프트 인젝션으로 생성된 도구 호출은 모델 출력과 분리된 Lease 및 정책 검증을 통과해야 하므로 스스로 실행 권한을 획득할 수 없다.

메시지 재사용 공격을 막으려면 연결 transcript에 결합된 인증과 중복 실행 방지 정보가 필요하다. 다른 전송 방식으로 전환하더라도 동일한 권한 객체와 상태 전이 규칙을 유지해야 한다. 증거가 변조되면 체인의 루트 해시가 달라지지만, 모든 영수증 서명 주체를 장악한 공격자는 일관된 허위 기록을 만들 수 있다. 또한 평문을 처리하는 Relay가 악의적이라면 내용을 열람하고 사건을 누락하거나 왜곡할 수 있다. 구성 요소별 영수증, 제한된 보존 기간, 독립적인 외부 반출, 선택적 payload 보호는 이러한 신뢰 의존성을 낮추지만 완전히 제거하지는 못한다.

이러한 보안 속성은 PAPER의 검증 프로파일을 요구한다. 체크인된 로컬 개발 프로파일은 설치 편의를 위해 자체 서명 인증서와 단순화된 증명 발급을 사용한다. 상용 프로파일은 조직 발급 피어 자격 증명, 인증서 검증, 폐기 상태, transcript 결합 증명 검증을 사용한다. 두 프로파일은 동일한 Harness - Relay - PIA 제품 경로를 사용하지만 서로 다른 보증 수준을 제공한다.

13 점진적 게이트웨이 전환

하나의 프로토콜 커널은 wire 의미를 분기하지 않고 활성 모듈, 정책 기본값, 보존, 이동성, 인프라 배치를 달리하여 퍼블릭 클라우드, 엔터프라이즈, 소버린 프로파일을 지원한다. 소버린 배포는 로컬 PKI, 카탈로그, PIA 엔드포인트, 오프라인 서명 업데이트 번들을 사용할 수 있다. 다만 벤더 간 상호운용성은 별도의 경험적 주장이며 프로파일 지원만으로 추론하지 않는다.

PCCP의 brownfield 도입 절차는 호출자 목록화, 카탈로그/제어 스키마의 추가적 도입, 기존 게이트웨이와 PAPER Relay의 병행 관찰, 비교 요청의 이중 기록, Harness cohort별 canary, rollback 게이트로 구성된다. Patty Code는 전환된 클라이언트 경계를 구현한다. 공식 Harness는 서비스 통신에 PAPER를 사용하고 일반 모델 제공자 fallback을 노출하지 않는다. 관리 API와 PIA 로컬 어댑터 API는 설계상 Harness 신뢰 경로 밖에 남는다.

14 논의: 프로토콜 적용 범위와 결과 거버넌스

PAPER는 에이전트 프로토콜이 메시지 전달뿐 아니라 메시지가 일으키는 결과도 표현해야 함을 시사한다. 텍스트만 반환하는 시스템에는 요청 인증과 응용 로그가 충분할 수 있다. 비공개 컨텍스트를 외부에 공개하고, 도구를 실행하며, 저장소를 변경하고, 지속되는 산출물을 만드는 시스템에서는 프로토콜 경계에서 상태 전이에 대한 권한도 다루어야 한다.

PAPER는 인접 표준을 대체하지 않고 상보적으로 사용한다. 적용 범위는 응용이 만드는 변경의 지속성과 권한 수준에 따라 결정할 수 있다. 채팅 응용은 저장소 도구를 활성화하지 않은 채 신원 확인, 모델 사용 통제, 감사 증거 기능을 사용할 수 있고, 코딩 에이전트는 외부 상태 변경을 위한 Capability를 추가할 수 있다.

응용 범위. 추론, 도구, 컨텍스트, 파일, 채팅, 멀티모달 입력, 지시문은 신원 및 세션 인프라를 공유하면서 Capability 단위로 분리된다. 이 구조 덕분에 일반 채팅 응용도 Patty Code와 동일한 프로토콜 코어를 사용하되 파일 변경이나 도구 실행 권한은 상속하지 않을 수 있다.

상태와 운영. Lease, Epoch, 재개, 폐기, 카탈로그, 증거는 운영 부담을 더한다. 캐시 노후화와 Control Plane 분할에는 명시적 fail-closed, bounded-stale, degrade 동작이 필요하다. 이진 프레이밍에는 일급 진단 및 캡처 도구도 필요하다.

프라이버시. 세밀한 프로비넌스 기록은 직원 감시 수단으로 변질될 수 있다. 따라서 수집 목적의 제한, 최소 수집, 역할별 접근 통제, 보존 기간 제한, 선택적 외부 반출, 사전 고지가 필요하다. 콘텐츠 해시를 사용한다고 해서 민감 정보가 익명화되는 것은 아니며, salt가 없는 해시는 원문 추측 공격에 노출될 수 있다.

배포 및 보증 프로파일. 구현된 제품은 Harness-Relay-PIA 전체 경로를 포괄하며, 검증 자료는 보증 프로파일별로 구성한다. 측정 프로파일은 핵심 연산의 지연시간, 처리량, 메모리 할당량을 제공한다. 상용 프로파일은 조직이 발급한 피어 자격 증명, 인증서 검증, 폐기 상태, transcript 결합 증명 검증을 사용한다. 연구 보증 행렬은 확장성, 프로비넌스 판별 정확도, 상호운용성, 형식 분석을 한층 더 심화하는 실험을 제시한다. 이 구분은 미들웨어 설정에 숨어 있던 배포 요건을 명시적인 공학적 선택으로 전환한다.

형식 분석. 상태 전이 모델과 불변조건은 형식 검증의 대상으로 삼을 수 있다. 본 논문은 형식적 보안 증명을 제공하지 않으며, 프로비넌스는 각 구성 요소에 대한 명시적 신뢰 가정 아래 기록된 인과관계를 검증한다. 기록 내용의 의미적 정확성과 실제 저작 주체는 별도의 검증 대상이다.

15 윤리와 감시 위험

프롬프트, 파일, 도구 사용, 편집, 인간 판단에 관한 증거는 사고 대응과 책임성을 향상시키지만 과도한 모니터링을 가능하게 할 수 있다. 프로토콜이 보존 및 반출 프로파일을 지원하더라도 기술적 설정만으로는 충분하지 않다. 배포자는 적절한 목적, 직원 고지, 접근 검토, 이의 제기, 정보주체 처리, 보안 조사와 성과 관리의 분리를 마련해야 한다. 공개 배포는 운영에 필요한 최소 추적을 기본값으로 삼고, 규제 배포는 정책 영역별로 더 깊은 보존의 필요성을 입증해야 한다.

그림 1과 그림 2에는 생성형 개념 이미지를 사용했으며, 두 그림은 프로토콜 구조를 설명할 뿐 측정이나 사실 비교를 포함하지 않는다. 그림 3은 LaTeX 기반 프로토콜 설계도이다. 그림 4와 경험적 표는 체크인된 벤치마크 데이터셋에서 생성한다. 보존된 중앙값은 벤치마크 하네스로 재현할 수 있으며, 새로운 통계적 주장을 위해서는 개별 실행 원자료를 별도로 공개해야 한다.

16 재현 가능성

arXiv 소스 패키지는 정확한 LaTeX 소스, 참고문헌, 개념 그림, 벤치마크 데이터셋, 빌드 지침을 포함한다. 개방형 구현 저장소에는 프로토콜 라이브러리, Relay, PIA, Control Plane 서비스, vLLM/SGLang 어댑터, PIA SDK 예제, 레지스트리, 벤치마크 하네스, 배포 자료가 포함되며, Patty Code 저장소에는 공식 Harness 통합이 포함된다. 구현 저장소 루트에서 다음 명령으로 보고된 핵심 연산 측정을 재현할 수 있다.

```
go test ./internal/paper -run '$' -bench 'Benchmark(...)' -benchmem -count=5
```

전체 정규식은 아티팩트 README에 제시한다. PDF는 latexmk와 BibTeX로 오프라인 빌드할 수 있다. 개별 실행 원자료, 네트워크/부하 생성기, 토폴로지 자동화, 부정 보안 fixture, 프로비던스 데이터셋, 독립 구현 결과는 각각 더 강한 통계, 확장성, 공격 저항성, 충실도, 상호운용성 주장을 제시할 때 요구된다.

17 결론

AI가 생성한 커밋의 책임성을 평가하려면 토큰을 생성한 모델의 식별만으로는 충분하지 않다. 사용자의 지시에서 실제 시스템 변경에 이르는 과정이 컨텍스트 공개, 모델 결정, 도구 승인, 산출물 생성 전반에 걸쳐 제한된 권한 안에서 수행되었음을 확인할 수 있어야 한다.

PAPER는 이 과정을 Governed Exchange로 표현한다. 신원, 작업 목적, 제한된 Capability, 변경 불가능한 정책, 모델과 패키지의 결정 과정, 실시간 정책 집행, 인과관계 증거를 하나의 프로토콜 처리 과정에 결합한다. 모델 출력은 제안으로 유지되고, 독립적인 프로토콜 상태 전이가 보호 작업을 승인한다. 최종 영수증은 각 상태 변경이 허용된 근거와 그 결과가 산출물에 반영된 과정을 기록한다.

구현체는 프로토콜 코어와 거버넌스 서비스, 서비스 추론에 PAPER를 사용하는 공식 Patty Code Harness, Relay-PIA 통신 경로, 재사용 가능한 vLLM/SGLang 어댑터, 채팅·코파일럿·자동화·사용자 정의 엔진을 위한 SDK 인터페이스를 포함한다. 측정된 핵심 연산 묶음은 비교에 사용한 상호작용형 TTFT 예산의 0.0097%를 차지하며, 1 MiB Record 처리량은 10.81 GB/s였다. 보증 행렬은 각 추가 보안 및 시스템 수준 주장에 대응하는 검증 수준을 제시한다.

공개 명세, 통합 구현, 핵심 연산 측정 결과는 거버넌스를 응용, 정책 관리 체계, 모델 인프라, 도구, 인과관계 증거를 연결하는 공통 프로토콜 속성으로 구현할 수 있음을 뒷받침한다. 이를 통해 시스템 변경에 대한 권한을 모델 출력이나 배포별 관례가 아니라 명시적이고 검증 가능한 프로토콜 상태로 표현한다.

참고문헌

- [1] A2A Project. Agent2Agent protocol specification, 2026. <https://a2a-protocol.org/latest/specification/>.
- [2] R. Barnes, K. Bhargavan, and C. A. Wood. Hybrid public key encryption. Technical Report RFC 9180, IETF, Feb. 2022. <https://www.rfc-editor.org/info/rfc9180>.
- [3] H. Birkholz, A. Delignat-Lavaud, C. Fournet, Y. Deshpande, and S. Lasker. An architecture for trustworthy and transparent digital supply chains. Technical Report RFC 9943, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9943>.
- [4] C. Bormann and P. Hoffman. Concise binary object representation (CBOR). Technical Report RFC 8949, IETF, Dec. 2020. <https://www.rfc-editor.org/info/rfc8949>.
- [5] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. *arXiv preprint arXiv:2406.13352*, 2024. <https://arxiv.org/abs/2406.13352>.

- [6] L. Fan, Z. Li, Y. Tian, Y. Wang, R. Li, and X. Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the llm reasoning bottleneck. *arXiv preprint arXiv:2605.11039*, 2026. <https://arxiv.org/abs/2605.11039>.
- [7] in-toto Project. in-toto specification v1.0, 2023. <https://in-toto.io/docs/specs/>.
- [8] J. Iyengar and M. Thomson. QUIC: A UDP-based multiplexed and secure transport. Technical Report RFC 9000, IETF, May 2021. <https://www.rfc-editor.org/info/rfc9000>.
- [9] MLCommons. MLPerf Inference v5.0 advances language model capabilities for GenAI, Apr. 2025. <https://mlcommons.org/2025/04/llm-inference-v5/>.
- [10] Model Context Protocol Project. Model context protocol specification, 2025-06-18 revision, 2025. <https://modelcontextprotocol.io/specification/2025-06-18>.
- [11] E. Rescorla. The transport layer security (tls) protocol version 1.3. Technical Report RFC 9846, IETF, July 2026. <https://www.rfc-editor.org/info/rfc9846>.
- [12] J. Schaad. CBOR object signing and encryption (COSE): Structures and process. Technical Report RFC 9052, IETF, Aug. 2022. <https://www.rfc-editor.org/info/rfc9052>.
- [13] SLSA Project. SLSA specification v1.2, 2026. <https://slsa.dev/spec/v1.2/>.
- [14] SPIFFE Project. Secure production identity framework for everyone standard, 2026. <https://spiffe.io/docs/latest/spiffe-specs/spiffe/>.
- [15] O. Steele, H. Birkholz, A. Delignat-Lavaud, and C. Fournet. CBOR object signing and encryption (COSE) receipts. Technical Report RFC 9942, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9942>.
- [16] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappelletti. in-toto: Providing farm-to-table guarantees for bits and bytes. In *28th USENIX Security Symposium*, pages 1393--1410, 2019.
- [17] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo. MI9: An integrated runtime governance framework for agentic ai. *arXiv preprint arXiv:2508.03858*, 2025. <https://arxiv.org/abs/2508.03858>.

A 연구 불변조건 보증 행렬

표 5는 평가 대상 커밋의 적합성 테스트가 각 연구 불변조건을 어느 범위까지 검증하는지 분석한 결과이다. “약함”은 테스트 이름이 나타내는 전체 조건 중 일부만 검증식으로 확인한 경우를, “부분”은 의미 있는 핵심 연산 또는 상태를 검사했지만 중단 간 경로 전체를 검증하지 않은 경우를 뜻한다.

표 5: 후보 연구 불변조건 검증 범위 분석.

ID	후보 불변조건	범위	검사 결과
I1	피어 인증 전에는 보호 대상 작업을 수행할 수 없음	부분	연결 상태 차단은 검증하지만 수신부의 증명 검증은 전체 경로를 확인하지 않음
I2	유효한 Capability Lease 범위 밖의 작업을 수행할 수 없음	약함	작업 권한이 아니라 자격 증명의 시간 유효성만 검사
I3	등록되지 않은 Policy Epoch으로 작업을 수행할 수 없음	약함	Epoch 조회 및 거부가 아니라 연결 준비 상태만 검사
I4	미승인 패키지 또는 Endpoint Lease로 호출할 수 없음	부분	서명 변조는 검사하지만 전체 라우팅 경로와의 연결은 검증하지 않음
I5	도구 제안만으로 실행 권한을 얻을 수 없음	약함	유효한 피어 자격 증명만 검사
I6	컨텍스트 공개에는 명시적 권한이 필요함	없음	해당 조건을 직접 검증하는 적합성 테스트가 없음
I7	대체 전송 경로에서도 동일한 권한 규칙이 유지됨	약함	ALPN 상수만 검사하고 대체 전송을 통한 교환은 검증하지 않음
I8	재연결 시 완료된 작업을 중복 실행하지 않음	검증 없음	테스트 이름은 존재하지만 검증식이 없음
I9	보호 교환은 검증 가능한 증거를 남기고 종료됨	부분	결정적 체인은 검사하지만 종료 및 영수증 발급 경로는 검증하지 않음
I10	프로비넌스 데이터 변경 시 다이제스트가 달라짐	핵심 연산 구현	서로 다른 콘텐츠가 domain-separated digest를 다르게 생성
I11	피어 프로파일에 허용되지 않은 특권 메시지를 보낼 수 없음	검증 없음	메시지 목록은 생성하지만 실제 집행 경로에 입력하지 않음
I12	관리 통신과 집행 통신은 구별됨	구조 검증	서로 다른 메시지 유형 코드를 사용하는지 검사

A.1 더 강한 주장에 필요한 증거

다음 실험은 시스템 수준 성능, 보안, 프로비넌스, 상호운용성 주장에 대응하는 검증 자료를 확장한다.

- 전송 및 인증:** 인증서와 COSE 증명의 전체 검증, 폐기, transcript 결합, 재개, QUIC – TCP fallback을 시험하고 연결 p50/p95/p99를 측정한다.
- 중단 간 추론:** 동일한 payload 및 모델 출력으로 B0 – B4를 비교하고 Relay Verdict 지연, TTFT, 스트리밍 처리량, CPU, 할당, 메모리를 보고한다.
- 거버넌스 부정 사례:** 실제 Relay 경로에서 만료되거나 재사용된 Lease, 미등록 Epoch, 오래된 카탈로그, 미승인 패키지, 유효하지 않은 엔드포인트, 피어 프로파일에 허용되지 않은 메시지, 완료 작업의 중복 실행을 거부하는지 검증한다.
- 확장성과 장애:** 동시 세션 및 스트림 수 증가, Relay 재시작, Control Plane 연결 중단, bounded-stale 캐시, 용량 할당 정보 손실, 증거 저장소 성능 저하의 영향을 측정한다.
- 프로비넌스 충실도:** 인간 편집, 파일/함수 이동, rebase, merge, 다중 에이전트 변경을 포함한 레이블 데이터 셋을 공개하고 정밀도, 재현율, 신뢰도 보정을 제시한다.
- 독립 증거:** 동일한 구현 스택을 공유하지 않는 구현을 시연하고 golden vector 및 fuzz 결과를 공개하며 상용 보안 프로파일에 대한 외부 검토를 수행한다.